EWB Cybersecurity Assessment 01: Security Foundations

Name: Ashwanthika K S

Program: AI-Powered Cybersecurity Internship, EWB EDUTECH PRIVATE LIMITED

Batch/group: AICTE internship cohort (no batch number assigned)

Task A: Secure a student account

Risk	Asset	CIA impact	Control	Limitation
Reused short password	Email, portal	Confidentiality, integrity: one leak opens both	Unique passphrases in a password manager	The master password becomes a single point of failure
Approving unexpected prompts	Account session	Confidentiality, integrity: attacker enters with her approval	Deny and report; use number-matching prompts	A convincing prompt can still trick her
Postponed updates	Laptop	Confidentiality, integrity, availability: known flaws let malware in	Automatic updates	Cannot stop unknown flaws
Single project copy	Project files	Availability: loss or theft destroys the work	Cloud copy plus external drive	Sync can copy corruption
Friend uses her signed-in account	Sessions, files, email	Confidentiality, integrity	Lock the screen; give the friend a guest account	Relies on habit

Priorities: (1) unique passwords, because one leak exposes everything and the fix is cheap; (2) correct handling of MFA prompts, because MFA is the backstop when a password is stolen; (3) ending shared use of her account, because it gives immediate access. Updates and backups follow, as they protect against flaws and loss rather than entry.

Authentication vs authorisation: Authentication proves who Mira is, such as her password and MFA approval. Authorisation decides what she can do, such as viewing her own grades but not editing others'. If her friend uses her signed-in session, the portal treats the friend as Mira.

Task B: Suspicious message

Warning sign	Why it needs scrutiny
"expires in 20 minutes"	Artificial urgency discourages checking
Sender campus-awards.example, Reply-To	Neither matches campus.example, and replies go to a

Warning sign	Why it needs scrutiny
personal-awards.example	different domain
"enter your college password and OTP"	Genuine organisations do not ask for OTPs
"Do not contact the college office"	Blocks the check that would expose it
"photo of your identity card"	Sensitive data with no legitimate need

Verification and response plan:

1. Do not click or reply. Type the college portal address yourself.
2. Confirm the scholarship through a contact from the official site.
3. HTTPS only encrypts the connection, and a display name can be set to anything, so neither proves the sender is genuine.
4. If a password and OTP were entered, change the password through the official portal, sign out other sessions and remove unknown MFA devices.
5. Report to the college IT helpdesk and scholarship office through official contacts, and tell them if an ID photo was sent.
6. Follow up: review sign-in activity, forwarding rules and recovery details, and change reused passwords.

B4: The message cannot show who really sent it or whether the scholarship exists. Full email headers (SPF/DKIM/DMARC) and confirmation from the scholarship office would help.

Task C: Sign-in alert

C1: Timeline

1. **Observed:** 09:00-09:01, sign-in and MFA from the usual IP 192.0.2.10. **Interpretation:** normal, and consistent with the student's statement.
2. **Observed:** 10:14-10:16, two failed passwords then a success from 198.51.100.23. **Interpretation:** possible guessing or reuse; a student typing error is not ruled out.
3. **Observed:** 10:17 MFA denied, 10:18 approved; the student says they approved a prompt to stop the requests. **Interpretation:** looks like MFA fatigue.
4. **Observed:** session created at 10:20 from the new IP. **Interpretation:** someone other than the student may have access.

C2: Explanations. Likely: the password was obtained, repeated prompts were triggered, and the student approved one. Alternative: the student or an acquaintance signed in from another network and the statement is mistaken. Checks: (1) compare the session's device and browser with known devices; (2) review what the session accessed and whether other accounts saw the same IP. An IP address does not identify a person.

C3: Actions for IT

1. Protect the account: end sessions, reset the password, revoke tokens, review MFA devices.
2. Preserve evidence: export authentication, MFA and session logs before they rotate.
3. Scope the incident: check mailbox rules, files accessed and other accounts.

C4: Summary. At 10:14-10:20 IST on 18 October, student07's account recorded two failed passwords, a success, a denied then approved MFA prompt, and a new session from 198.51.100.23, which differs from the usual classroom IP 192.0.2.10. The student says they did not sign in and approved a prompt to stop repeated requests. This suggests possible MFA fatigue, but the IP alone does not identify anyone, and legitimate use is not ruled out. Priority: medium-high. Next: IT should end the session, reset the password, preserve logs and review account activity.

Task D: AI output review

D1: Corrections

1. "Safe because of HTTPS": HTTPS only encrypts the connection; verify the sender and domain independently.
2. "Logs prove that person stole the password": logs show events from an IP, not who was behind it or how the password was obtained.
3. "MFA prevents every compromise": it reduces risk but not completely; Task C shows a compromise through an approved prompt.
4. "Delete the suspicious logs": this destroys evidence; preserve them.
5. "Send the password to support": passwords are never shared; reset it instead.

D2: Better prompt

> *Analyse only the fictional evidence below. Separate observed facts, assumptions and what cannot be known. Do not ask for passwords, OTPs or personal data. State your uncertainty and what extra evidence would reduce it.*

D3: Corrected advice (107 words)

A link using HTTPS is not proof a message is safe; HTTPS only encrypts the connection. Check the sender's address. Confirm requests through the college's official website or office. Sign-in logs show events from an IP address, not who was behind them, so report findings as likely, not proven. MFA greatly reduces risk but cannot prevent every compromise, especially when a user approves a prompt they did not start. Preserve logs as evidence and never delete them. Never share your password or OTP with anyone, including support. If you suspect compromise, change the password through the official portal, sign out other sessions and report it to IT.

D4: AI-use declaration and references

AI use : I used Claude to draft the answers and checked them against the CISA and NIST references. I reviewed and edited the draft but did not fully rewrite it.

1. CISA, Secure Our World: phishing, MFA, strong passwords, updates. https://www.cisa.gov/secure-our-world
2. NIST, Generative AI Profile (AI 600-1): verifying AI output. https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf